UNIVERSITI TEKNOLOGI MARA
MARKING SCHEME

COURSE	:	COMPUTER SECURITY
COURSE CODE	:	CSC662
EXAMINATION	:	OCTOBER 2026 (MOCK)
TIME	:	3 HOURS

MARKING SCHEME NOTES

1. This marking scheme accompanies the CSC662 mock paper (October 2026). Computed answers show working; theory answers are supported by lecture slides (not lecturer-marked) with a verbatim quote and slide citation.

2. Supported theory marking points quote the lecture decks; any unresolved slot would remain a visible placeholder.

3. Part A = 10 x (2 + 6); Part B = 2 x (5 + 5); total = 100 marks.

4. Computed: 2 slot(s). Supported theory: 22 slots. Placeholders: 0. Questions and answers are for local study use only.

5. Near-copy rejection used all 35 past papers; style widening is recorded per slot.

FOR MARKERS' USE ONLY

This marking scheme consists of 14 printed pages

© Hak Cipta Universiti Teknologi MARA

CSC662 - MARKING SCHEME (MOCK OCTOBER 2026)

Labels: computed / supported by lecture slides (not lecturer-marked) / placeholder. No official marking scheme exists for the real CSC662 papers; this is generated for the mock.

Entailment labels: supported = the quote directly supports the marking point (or the point passed the stem-overlap gate without an LLM check); partly supported = the quote supports part of the point or is ambiguous; not supported = the quote does not support the point. Only 'not supported' points triggered regeneration.

Part A: 10 x (2 + 6) = 80 marks. Part B: 2 x (5 + 5) = 20 marks. Total: 100 marks. Slots: 2 computed, 22 supported by lecture slides, 0 placeholder.

Methods: computed answers use verified solvers. Theory answers are supported by lecture slides (not lecturer-marked). Each marking point carries a verbatim quote, a deck/slide/chunk citation and a term-overlap score; low overlap is flagged for human review. Sources are restricted to the slot topic's allowed decks, and a slide is not reused across questions where an alternative exists.

PART A - QUESTION 1

A1a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

State TWO (2) typical locations for placing network-based IDS sensors.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	A sensor can be positioned just inside the firewall.	"Just inside the firewall"	062 - Intrusion Detection System, slide 7	062 - Intrusion Detection System::s07::1	0.50	supported (ste gate)
2	A sensor can be positioned on the DMZ.	"On the DMZ"	062 - Intrusion Detection System, slide 7	062 - Intrusion Detection System::s07::1	0.25 LOW	supported

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 062 - Intrusion Detection System, slide 7

A1b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain three preventive network security mechanisms that an organization can deploy, describing how each mechanism protects the network.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	A firewall filters traffic entering and leaving the network according to predefined security rules.	"Control incoming and outgoing traffic on network with predetermined security policies."	061 - Network Security, slide 3	061 - Network Security::s03::1	0.30 LOW	supported
2	A proxy server improves data security and network performance by acting as a firewall and web filter, sharing connections and caching data.	"Proxy servers act as a firewall and web filter, provide shared network connections, and cache data to speed up common requests."	061 - Network Security, slide 3	061 - Network Security::s03::1	0.79	supported (ste gate)
3	Network segmentation creates boundaries between segments whose assets share a common function, risk or role.	"Boundaries between network segments where computing assets within the segment have a common function, risk or role within an organization."	061 - Network Security, slide 3	061 - Network Security::s03::1	0.75	supported (ste gate)
4	A remote access VPN gives individual hosts or	"Provides remote and secure access to an organization network	061 - Network Security, slide 4	061 - Network Security::s04::1	0.89	supported (ste gate)

© Hak Cipta Universiti Teknologi MARA

	clients secure access to the organization's network.	to individual hosts or clients"				
5	Zero Trust Network Access limits each user to only the access and permissions needed for their role.	"A user should only has access and permission that required to fulfill the role"	061 - Network Security, slide 4	061 - Network Security::s04::1	0.50	supported (ste gate)
6	IDS/IPS detect or prevent attacks such as brute force, denial-of-service and exploitation of network vulnerabilities.	"To detect or prevent the network security attacks such as brute force attacks, Denial-of-Service attacks and exploits of network vulnerabilities."	061 - Network Security, slide 4	061 - Network Security::s04::1	0.85	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 061 - Network Security, slide 3; 061 - Network Security, slide 4

PART A - QUESTION 2

A2a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain how a substitution cipher works and what serves as its key.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Encryption replaces each plaintext letter with a different letter to produce the ciphertext.	"In substitution ciphers, we replace the plain-text letters with other letters"	031 - Classical Cryptography, slide 4	031 - Classical Cryptography::s04::1	0.33 LOW	supported
2	The substitution rule itself acts as the key of the cipher.	"The substitution rule is the key"	031 - Classical Cryptography, slide 4	031 - Classical Cryptography::s04::1	0.40 LOW	supported

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 031 - Classical Cryptography, slide 4

A2b - 6 marks - computed - matches lecture slide 15 (standard tableau)

Question:

Decrypt the following ciphertext using the Vigenere cipher with the key CIPHER. Use the standard 26 x 26 Vigenere tableau, writing the key over the message and repeating it as necessary.
UMRBVVNWVPREQE

Answer: SECURELOGINNOW

The 26 x 26 Vigenere tableau is printed in the question paper.

Working:

```
Standard 26 x 26 tableau, A=0; key repeated over the ciphertext.
Ciphertext: UMRBVVNWVPREQE
Key:        CIPHERCIPHERCI
Letter-by-letter: C - K mod 26 = P
  U (20) - C ( 2) = 18 -> S
  M (12) - I ( 8) =  4 -> E
  R (17) - P (15) =  2 -> C
  B ( 1) - H ( 7) = 20 -> U
  V (21) - E ( 4) = 17 -> R
  V (21) - R (17) =  4 -> E
  N (13) - C ( 2) = 11 -> L
  W (22) - I ( 8) = 14 -> O
  V (21) - P (15) =  6 -> G
  P (15) - H ( 7) =  8 -> I
  R (17) - E ( 4) = 13 -> N
  E ( 4) - R (17) = 13 -> N
  Q (16) - C ( 2) = 14 -> O
```

© Hak Cipta Universiti Teknologi MARA

```
  E ( 4) - I ( 8) = 22 -> W
Plaintext:  SECURELOGINNOW
```

Suggested marks: 1 mark for the key/table setup; 4 marks for the letter-by-letter working; 1 mark for the complete answer.
Confidence: computed - matches lecture slide 15 (standard tableau).

PART A - QUESTION 3

A3a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

List two formal security models and state the specific concern each one addresses.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	The Bell-La Padula (BLP) model is a formal security model that deals with access control only.	"Bell-La Padula (BLP) model: access control only"	024 - Formal Security Model, slide 5	024 - Formal Security Model::s05::1	0.70	supported (ste gate)
2	The Chinese Wall model is designed to address conflicts of interest for a consultant or contractor.	"Brewer and Nash's Chinese Wall Policy is designed to address a very specific concern: conflicts of interest by a consultant or contractor."	024 - Formal Security Model, slide 27	024 - Formal Security Model::s27::1	0.89	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 024 - Formal Security Model, slide 27; 024 - Formal Security Model, slide 5

A3b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

State six points about access control structures, covering the access control matrix, access control lists and capability lists, including one advantage and one disadvantage of each structure.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	The access control matrix is described as a basic control structure.	"ACM is a basic control structure."	023 - Access Control and Authorization, slide 8	023 - Access Control and Authorization::s08::1	0.60	supported (ste gate)
2	An advantage of the access control matrix is that it is easy to verify.	"Advantages: clarity of definition easy to verify"	023 - Access Control and Authorization, slide 8	023 - Access Control and Authorization::s08::1	0.50	supported (ste gate)
3	A disadvantage of the access control matrix is poor scalability.	"Disadvantages: poor scalability poor handling of changes"	023 - Access Control and Authorization, slide 8	023 - Access Control and Authorization::s08::1	0.50	supported (ste gate)
4	An access control list is an object-centered description of access rights.	"ACL is an object-centered description of access rights:"	023 - Access Control and Authorization, slide 10	023 - Access Control and Authorization::s10::1	0.83	supported (ste gate)
5	An advantage of ACLs is that object access rights are easy to access.	"Advantages: easy access to object access rights relative easiness of management using abstractions"	023 - Access Control and Authorization, slide 10	023 - Access Control and Authorization::s10::1	0.83	supported (ste gate)
6	A capability list is a subject-centered description of access rights.	"C-List is a subject-centered description of access rights:"	023 - Access Control and Authorization, slide 9	023 - Access Control and Authorization::s09::1	0.83	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 023 - Access Control and Authorization, slide 10; 023 - Access Control and Authorization, slide 8; 023 -

Access Control and Authorization, slide 9

PART A - QUESTION 4

A4a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain the goals of access control and the role of a reference monitor.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Access control aims to grant access to subjects.	"Goals of access control: Granting access"	023 - Access Control and Authorization, slide 4	023 - Access Control and Authorization::s04::1	0.60	supported (ste gate)
2	Access control aims to limit access.	"Limiting access"	023 - Access Control and Authorization, slide 4	023 - Access Control and Authorization::s04::1	0.50	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 023 - Access Control and Authorization, slide 4

Status: computed placeholder - no question generated for this type.

PART A - QUESTION 5

A5a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

State TWO (2) characteristics of Trojan horse malware.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Trojans typically disguise themselves as useful or benign programs.	"They usually masquerade as helpful or harmless programs"	051 - Software Security, slide 12	051 - Software Security::s12::1	0.17 LOW	supported
2	Trojans steal private data from the infected host.	"begin to steal private data, delete files, log keystrokes or provide an opening for further malware to get installed"	051 - Software Security, slide 12	051 - Software Security::s12::1	0.50	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 051 - Software Security, slide 12

A5b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Describe six (6) techniques used by malware to propagate itself or to hide and maintain control of an infected system.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	A boot sector virus saves the original master boot record in a safe location before overwriting it with an infected version.	"Save the original MBR in a safe location"	051 - Software Security, slide 8	051 - Software Security::s08::1	0.31 LOW	supported
2	A COM executable virus replaces the program entry point with a jump to the virus body, which later restores the original entry point.	"Replace a program entry point with a jump to a virus body"	051 - Software Security, slide 9	051 - Software Security::s09::1	0.58	supported (ste gate)

© Hak Cipta Universiti Teknologi MARA

3	An EXE executable virus overwrites the program header so that the entry point switches to the virus.	"Over write a program header to switch the entry point to a virus"	051 - Software Security, slide 10	051 - Software Security::s10::1	0.67	supported (ste gate)
4	A rootkit masks malicious processes and software in the infected system so that privileged remote access is maintained.	"Rootkits are a type of malware that mask malicious processes and software in the infected systems to ensure privileged remote access."	051 - Software Security, slide 13	051 - Software Security::s13::1	0.91	supported (ste gate)
5	A rootkit is usually installed after a vulnerability has been found and detected, keeping the infected computer under the malware author's control.	"They are usually installed after a vulnerability has been found and detected so that the infected computer continues to be under the control of the malware author."	051 - Software Security, slide 13	051 - Software Security::s13::1	0.87	supported (ste gate)
6	Spyware steals user logins and passwords, records sites visited, logs keystrokes and redirects browsers to unwanted sites.	"They steal user logins and passwords, document sites visited, log keystrokes and even redirect browsers to unwanted sites."	051 - Software Security, slide 13	051 - Software Security::s13::1	0.85	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 051 - Software Security, slide 10; 051 - Software Security, slide 13; 051 - Software Security, slide 8; 051 - Software Security, slide 9

PART A - QUESTION 6

A6a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain how a disclosure threat impacts confidentiality and how a disruption threat impacts availability.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	A disclosure threat is an unauthorized access to information, which harms confidentiality.	"Disclosure - unauthorized access to information"	011 - Introduction to Computer Security, slide 10	011 - Introduction to Computer Security::s10::1	0.57	supported (ste gate)
2	A disruption threat interrupts or prevents correct operation, which harms availability.	"Disruption - interruption or prevention of correct operation"	011 - Introduction to Computer Security, slide 10	011 - Introduction to Computer Security::s10::1	0.62	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 011 - Introduction to Computer Security, slide 10

A6b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Describe the Samy worm as a malware case study, covering how it injected code, how it spread, and its outcome.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	The worm injected JavaScript into a user profile by writing to document.body.innerHTML.	"Inject Javascript into a user profile using document.body.innerHTML"	052 - Web Security, slide 15	052 - Web Security::s15::1	0.70	supported (ste gate)
2	It obtained the victim's list of friends (heros) by	"Get the list of user's heros by using a GET on a user profile"	052 - Web Security, slide	052 - Web Security::s15::1	0.33 LOW	supported

© Hak Cipta Universiti Teknologi MARA

	issuing a GET request on a user profile.		15			
3	It added Samy as a friend by performing XML-HTTP requests against the addFriends page.	"Add Samy as a field by performing XML-HTTP on the addFriends page"	052 - Web Security, slide 15	052 - Web Security::s15::1	0.70	supported (ste gate)
4	Any user visiting an infected profile had their own profile and friends list infected, so the worm spread through page visits.	"Any user who visits an infected user's page will gets profile infected with Javascript and his friends list infected with Samy"	052 - Web Security, slide 15	052 - Web Security::s15::1	0.50	supported (ste gate)
5	The worm ultimately infected about 1,000,000 MySpace profiles, showing the large-scale impact of an XSS-based worm.	"Eventually about 1,000,000 MySpace profiles were infected."	052 - Web Security, slide 15	052 - Web Security::s15::1	0.31 LOW	supported
6	The underlying XSS weakness is that any web application returning user input without filtering is a potential XSS vulnerability.	"Any web application that returns user input without filtering is a potential XSS vulnerability!"	052 - Web Security, slide 13	052 - Web Security::s13::1	0.77	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 052 - Web Security, slide 13; 052 - Web Security, slide 15

PART A - QUESTION 7

A7a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

List TWO (2) stages of the biometric authentication process.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Identification stage, which involves acquisition, creation of master characteristics and their storage	"Identification Stage Acquisition Creation of Master characteristics Storage of Master characteristics"	072 - Biometrics and Authentication, slide 5	072 - Biometrics and Authentication::s05::1	0.86	supported (ste gate)
2	Authentication stage, which involves acquisition(s), comparison and decision	"Authentication Stage Acquisition(s) Comparison Decision"	072 - Biometrics and Authentication, slide 5	072 - Biometrics and Authentication::s05::1	0.83	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 072 - Biometrics and Authentication, slide 5

A7b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Discuss biometric mechanisms and technologies as an alternative to passwords, covering their definition, categories, and the strengths and weaknesses of specific biometric methods.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	A biometric is defined as a physiological or behavioural characteristic of a human that can distinguish one person	"A biometric is a physiological or behavioural characteristic of a human being that can distinguish one person from another and that theoretically can be used for identification or verification of identity."	072 - Biometrics and Authentication, slide 2	072 - Biometrics and Authentication::s02::1	0.92	supported (ste gate)

© Hak Cipta Universiti Teknologi MARA

	from another and can theoretically be used for identification or verification.					
2	Biometric applications are divided into two sectors: psychological (such as iris, fingerprints, hand, retinal and face recognition) and behavioural (such as voice, typing pattern and signature).	"Biometric applications available today are categorized into 2 sectors"	072 - Biometrics and Authentication, slide 4	072 - Biometrics and Authentication::s04::1	0.23 LOW	partly supporte
3	Retinal scanning is very efficient and cannot be spoofed, but it requires the user to look directly into the reader and raises acceptability concerns such as light exposure and hygiene.	"Very efficient - cant be spoofed!"	072 - Biometrics and Authentication, slide 9	072 - Biometrics and Authentication::s09::1	0.15 LOW	partly supporte
4	Fingerprint biometrics suffer from disadvantages including racial issues, dirt, grime and wounds, finger placement problems, and the need for liveness detection because they can be spoofed.	"Can be spoofed - liveness important!"	072 - Biometrics and Authentication, slide 7	072 - Biometrics and Authentication::s07::1	0.15 LOW	partly supporte
5	Iris scanning captures a unique pattern, is coloured and visible from far, requires no touch, and overcomes retinal scanner issues, although contact lenses may be a problem.	"Scans unique pattern of iris"	072 - Biometrics and Authentication, slide 10	072 - Biometrics and Authentication::s10::1	0.21 LOW	partly supporte
6	Biometric methods are one of the alternative user authentication mechanisms, alongside smart cards and two-factor authentication, to the common but insufficiently secure password.	"Alternative user authentication mechanisms are smart cards, biometric methods and two-factor authentication."	022 - Identification and Authentication, slide 24	022 - Identification and Authentication::s24::1	0.60	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 022 - Identification and Authentication, slide 24; 072 - Biometrics and Authentication, slide 10; 072 - Biometrics and Authentication, slide 2; 072 - Biometrics and Authentication, slide 4; 072 - Biometrics and Authentication, slide 7; 072 - Biometrics and Authentication, slide 9

PART A - QUESTION 8

A8a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain two password security controls used to protect user accounts.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Access control should be applied to password files so stored passwords are protected.	"Access control applied to password files"	022 - Identification and Authentication, slide 12	022 - Identification and Authentication::s12::1	0.50	supported (ste gate)

2	Accounts should be de-activated after multiple failed login attempts.	"De-activation of accounts after multiple failed logins"	022 - Identification and Authentication, slide 12	022 - Identification and Authentication::s12::1	0.75	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 022 - Identification and Authentication, slide 12

A8b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

State six facts about Kerberos and single sign-on as authentication mechanisms, covering their motivation, design criteria, login process and limitations.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Single sign-on reduces the need for users to memorize passwords.	"Reduce the need to memorize passwords"	022 - Identification and Authentication, slide 16	022 - Identification and Authentication::s16::1	0.57	supported (ste gate)
2	Single sign-on reduces the time users spend typing passwords.	"Reduce the time spent on typing passwords"	022 - Identification and Authentication, slide 16	022 - Identification and Authentication::s16::1	0.43 LOW	supported
3	Kerberos is designed to be secure against eavesdropping by never transmitting passwords in clear text.	"Security against eavesdropping: no password transmission in clear text."	022 - Identification and Authentication, slide 18	022 - Identification and Authentication::s18::1	0.60	supported (ste gate)
4	Kerberos is designed for transparency, so the user is unaware of any authentication beyond the initial login.	"Transparency: user is not aware of any authentication beyond an initial login."	022 - Identification and Authentication, slide 18	022 - Identification and Authentication::s18::1	0.70	supported (ste gate)
5	During Kerberos login, the hash of the user's password becomes the secret key of the client or user.	"The hash value of his password KU = h(P) becomes a secret key of the client/user."	022 - Identification and Authentication, slide 19	022 - Identification and Authentication::s19::1	0.67	supported (ste gate)
6	A limitation of Kerberos is that it is relatively complex to install.	"Relatively complex in installation."	022 - Identification and Authentication, slide 23	022 - Identification and Authentication::s23::1	0.60	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 022 - Identification and Authentication, slide 16; 022 - Identification and Authentication, slide 18; 022 - Identification and Authentication, slide 19; 022 - Identification and Authentication, slide 23

PART A - QUESTION 9

A9a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain how an intrusion detection system detects and responds to attacks.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	An IDS detects malicious activity occurring in computer systems.	"Detects malicious activity in computer systems"	062 - Intrusion Detection System, slide 2	062 - Intrusion Detection System::s02::1	0.71	supported (ste gate)
2	A passive detection system can only log	"Can take passive action (logging and alerting) when an attack is	062 - Intrusion Detection	062 - Intrusion Detection	0.50	supported (ste gate)

	and alert when an attack is identified, not stop it actively.	identified"	System, slide 29	System::s29::1		

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 062 - Intrusion Detection System, slide 2; 062 - Intrusion Detection System, slide 29

A9b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain the distinction between a vulnerability, a threat and an attack, and state three countermeasure activities that together protect assets against threats.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	A vulnerability is a weakness in a system that can be exploited to cause damage to assets.	"Vulnerabilities: Weakness of a system that can be exploited to damage assets"	011 - Introduction to Computer Security, slide 9	011 - Introduction to Computer Security::s09::1	0.88	supported (ste gate)
2	A threat is only a potential violation of security, not an actual one.	"Threats: A threat is a "potential" violation of security"	011 - Introduction to Computer Security, slide 9	011 - Introduction to Computer Security::s09::1	0.57	supported (ste gate)
3	An attack is the actual violation of security that has occurred.	"Attacks: The actual violation of security"	011 - Introduction to Computer Security, slide 9	011 - Introduction to Computer Security::s09::1	0.67	supported (ste gate)
4	A threat is an entity that represents a constant danger to an asset.	"Threat: object, person, or other entity representing a constant danger to an asset"	011 - Introduction to Computer Security, slide 28	011 - Introduction to Computer Security::s28::1	1.00	supported (ste gate)
5	An attack is a deliberate act that exploits a vulnerability.	"Attack: a deliberate act that exploits vulnerability"	011 - Introduction to Computer Security, slide 28	011 - Introduction to Computer Security::s28::1	1.00	supported (ste gate)
6	Protecting assets requires combining prevention, detection and response techniques as countermeasures.	"Protection of assets encompasses prevention, detection and response techniques"	011 - Introduction to Computer Security, slide 28	011 - Introduction to Computer Security::s28::1	0.67	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 011 - Introduction to Computer Security, slide 28; 011 - Introduction to Computer Security, slide 9

PART A - QUESTION 10

A10a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

State TWO (2) facts about the chain of trust in trusted computing.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Each stage of the chain measures and validates the following stage.	"Each stage measures and validates the next one"	073 - Trusted Computing, slide 8	073 - Trusted Computing::s08::1	0.60	supported (ste gate)
2	The measurements are recorded in Platform Configuration Registers on the TPM.	"Measurements go into Platform Configuration Registers (PCRs) on the TPM"	073 - Trusted Computing, slide 8	073 - Trusted Computing::s08::1	0.83	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.

© Hak Cipta Universiti Teknologi MARA

Citations: 073 - Trusted Computing, slide 8

A10b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Refer to your answer in (a). Explain six (6) facts about the NGSCB/Nexus components, covering the Nexus kernel, the Nexus Computing Agent, and how they relate to the TPM and the operating system.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Nexus is described as a security kernel that is authenticated on boot.	"Security kernel, authenticated on boot"	073 - Trusted Computing, slide 14	073 - Trusted Computing::s14::1	0.80	supported (ste gate)
2	Nexus authenticates trusted programs.	"Authenticates trusted programs"	073 - Trusted Computing, slide 14	073 - Trusted Computing::s14::1	0.75	supported (ste gate)
3	Nexus provides the application interface to the TPM.	"Application interface to TPM"	073 - Trusted Computing, slide 14	073 - Trusted Computing::s14::1	0.60	supported (ste gate)
4	Nexus does not trust the operating system.	"Does not trust OS"	073 - Trusted Computing, slide 14	073 - Trusted Computing::s14::1	0.50	supported (ste gate)
5	The Nexus Computing Agent is a trusted software component.	"Trusted software component"	073 - Trusted Computing, slide 15	073 - Trusted Computing::s15::1	0.40 LOW	supported
6	The NCA runs in trusted mode and communicates with Nexus.	"Runs in trusted mode that communicates with Nexus"	073 - Trusted Computing, slide 15	073 - Trusted Computing::s15::1	0.83	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 073 - Trusted Computing, slide 14; 073 - Trusted Computing, slide 15

PART B - QUESTION 1

B1a - 5 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain five points about software insecurity and buffer overflows, covering their root causes, how a stack buffer overflow hijacks execution, and one mitigation technique.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Software insecurity arises because an attacker can alter resources that are critical to program execution, such as the instruction pointer or function call addresses.	"Software insecurity stems from attacker's ability to modify system resources criticial for program execution, e.g. instruction pointer, function call addresses, interrupt addresses, etc."	051 - Software Security, slide 30	051 - Software Security::s30::1	0.65	supported (ste gate)
2	A major source of software insecurity is the failure to properly validate user input.	"One of the key sources for software insecurity is failed validation of user input."	051 - Software Security, slide 30	051 - Software Security::s30::1	0.67	supported (ste gate)
3	Buffer overflows are among the most widely used exploitation techniques.	"Buffer overflows are a most widely used exploitation technique."	051 - Software Security, slide 30	051 - Software Security::s30::1	0.71	supported (ste gate)
4	Without proper bounds checking, a local buffer can overspill into the adjacent upper stack area.	"Without proper bound checking a buffer content can overspill into adjacent upper stack area."	051 - Software Security, slide 21	051 - Software Security::s21::1	0.92	supported (ste gate)
5	By controlling the buffer contents, an attacker can overwrite the return address with an arbitrary value and	"By controlling buffer content, an attacker can overwrite the return address with an arbitrary value and hijack the execution flow."	051 - Software Security, slide 21	051 - Software Security::s21::1	0.86	supported (ste gate)

	thereby hijack the execution flow.					

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 051 - Software Security, slide 21; 051 - Software Security, slide 30

B1b - 5 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain five points about the security mechanisms built into Windows, covering the directory service used to organise resources, the registry hives that hold security data, how access rights are encoded, and why the complexity of these mechanisms can itself be a risk.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Active Directory, introduced in Windows 2000, is an LDAP-like directory service used to organise system resources such as users and groups, security credentials and certificates, and security policies.	"Active directory introduced in Windows 2000 is an LDAP-like directory service for organization of system resources:"	041 - Windows Security, slide 6	041 - Windows Security::s06::1	0.56	supported (ste gate)
2	The registry is a hierarchical database holding critical system information, and its security-related hives include SAM (the SAM database) and Security (security logs).	"A hierarchical database containing critical system information"	041 - Windows Security, slide 4	041 - Windows Security::s04::1	0.39 LOW	partly supporte
3	Access rights describe what one can do to an object and are encoded as a 32-bit mask, with standard rights such as DELETE and WRITE_DAC common to most object types.	"Describe what one can do to an object"	041 - Windows Security, slide 16	041 - Windows Security::s16::1	0.14 LOW	partly supporte
4	Windows contains complex mechanisms for user account and object management and access control, and DACS allow fine-grained access control of heterogeneous entities.	"Windows systems contain complex security mechanisms for user account and object management as well as access control."	041 - Windows Security, slide 21	041 - Windows Security::s21::1	0.62	supported (ste gate)
5	The complexity of Windows security mechanisms is also its enemy, because misconfiguration as well as implementation bugs may lead to severe security incidents.	"The complexity of Windows security mechanisms is also its enemy: misconfiguration as well as implementation bugs may lead to severe security incidents."	041 - Windows Security, slide 21	041 - Windows Security::s21::1	0.87	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 041 - Windows Security, slide 16; 041 - Windows Security, slide 21; 041 - Windows Security, slide 4; 041 - Windows Security, slide 6

PART B - QUESTION 2

B2a - 5 marks - supported by lecture slides (not lecturer-marked)

Scenario:

A computing professional at a company is asked to release a system that stores customers' personal information. Before release, the professional must weigh the traditions of belief about right and wrong conduct, the guiding beliefs of the profession, and the formal rules imposed by the government, and must also follow the ACM code of ethics and professional conduct.

Question:

Discuss the distinctions between morals, ethics and laws, and explain how the ACM code guides a computing professional's conduct when handling personal information. Support your discussion with examples from the code.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Morals are described as traditions of belief about right and wrong conduct, forming the bedrock of social behavior.	"Morals are traditions of belief about right and wrong conduct and "doing what is morally right" is the bedrock of our social behavior"	071 - Ethics and Computer Security, slide 5	071 - Ethics and Computer Security::s05::1	0.91	supported (ste gate)
2	Ethics is explained as a suite of guiding beliefs, standards or ideals that pervades an individual or a group or community.	"Ethics is a suite of guiding beliefs, standards, or ideals that pervades an individual or a group or community of people"	071 - Ethics and Computer Security, slide 5	071 - Ethics and Computer Security::s05::1	1.00	supported (ste gate)
3	Laws are formal rules of conduct imposed by a sovereign authority such as a government on its subjects or citizens.	"Laws are formal rules of conduct that a sovereign authority, such as a government, imposes on its subjects or citizens"	071 - Ethics and Computer Security, slide 5	071 - Ethics and Computer Security::s05::1	1.00	supported (ste gate)
4	The ACM code requires a computing professional to respect privacy when handling personal information.	"Respect privacy."	071 - Ethics and Computer Security, slide 11	071 - Ethics and Computer Security::s11::1	0.18 LOW	supported
5	The ACM code requires a computing professional to honor confidentiality.	"Honor confidentiality."	071 - Ethics and Computer Security, slide 11	071 - Ethics and Computer Security::s11::1	0.29 LOW	supported

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 071 - Ethics and Computer Security, slide 11; 071 - Ethics and Computer Security, slide 5

B2b - 5 marks - supported by lecture slides (not lecturer-marked)

Question:

State five professional conduct obligations from the ACM code that the professional in the scenario should follow when releasing the system that stores customers' personal information.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	The professional must aim for high quality in the processes and products of the professional work.	"Strive to achieve high quality in both the processes and products of professional work."	071 - Ethics and Computer Security, slide 12	071 - Ethics and Computer Security::s12::1	0.75	supported (ste gate)
2	The professional must uphold high standards of competence, conduct and ethical practice.	"Maintain high standards of professional competence, conduct, and ethical practice."	071 - Ethics and Computer Security, slide 12	071 - Ethics and Computer Security::s12::1	0.78	supported (ste gate)
3	The professional must be aware of and respect the existing rules that apply to the professional work.	"Know and respect existing rules pertaining to professional work."	071 - Ethics and Computer Security, slide 12	071 - Ethics and Computer Security::s12::1	0.62	supported (ste gate)
4	The professional must only access computing	"Access computing and communication resources only	071 - Ethics and Computer	071 - Ethics and Computer	0.75	supported (ste gate)

© Hak Cipta Universiti Teknologi MARA

	and communication resources when authorized or when the public good requires it.	when authorized or when compelled by the public good."	Security, slide 12	Security::s12::1		
5	The professional must design and implement systems that are both robustly secure and usable.	"Design and implement systems that are robustly and usably secure."	071 - Ethics and Computer Security, slide 12	071 - Ethics and Computer Security::s12::1	0.67	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 071 - Ethics and Computer Security, slide 12

End of marking scheme.

© Hak Cipta Universiti Teknologi MARA